

(Information Security System)

DATE: 16/2/25

PAGE NO.: 01

• Section - A (2x2 = 4)

1. Define integrity and non-integrity repudiation?

Ans Integrity :- Ensure data is accurate and unaltered during transmission or storage.

Non-repudiation :- Guarantees that a party cannot deny the authenticity of their action or communications.

2. Define Security? specify the four categories of security threats?

Ans Security refers to the protection of data, systems, and networks from unauthorized access, attacks, damage or theft to ensure confidentiality, integrity and availability.

Four categories of Security threats.

- i) Interruption - Disrupts system availability (e.g. - DOS attacks).
- ii) Interception - Unauthorized access to data (e.g. - MITM attacks).
- iii) Modification - Unauthorized alteration of data (e.g. - data breach).
- iv) Fabrication - Creation of false data or transactions (e.g. - phishing).

• Section - B (2x7 = 14)

1. Define Confidentiality and Authentication? What are the different components of information security system?

Ans Confidentiality :- Ensure that information is accessible only to authorized individuals and is protected from unauthorized access or disclosure.

Authentication :- The process of verifying the identity of a user, system or entity to ensure they are who they claim to be before granting access.

Components of an Information Security System :-

- (i) Confidentiality - protecting sensitive data from unauthorized access.

- (ii) Integrity - Ensuring data remains accurate and unaltered.
- (iii) Availability - Ensuring that systems and data are accessible when needed.
- (iv) Authentication - Verifying identities to allow access.
- (v) Authorization - Granting appropriate access levels to authenticated users.
- (vi) Non-repudiation - Preventing denial of actions by users through logs.
- (vii) Accountability - Tracking user activities to ensure compliance and traceability.

Q2. Explain in details active and passive attack with example?

Ans Security attacks can be broadly classified into active and passive attacks based on their impact on data and system integrity.

- (i) Passive Attack :- A passive attack involves monitoring or intercepting data without altering it. The attacker secretly observes communication to gather information without affecting system operations.

Characteristics:

- Difficult to detect because the attacker does not modify data.
- Focus on unauthorized access to information.

Example:

- Eavesdropping (Wiretapping) - An attacker listens to private conversations over a network.
- Traffic Analysis - An attacker analyzes communication patterns (e.g. frequency, timing) to infer sensitive details.
- Shoulder Surfing - Watching someone enter passwords or PINs without their knowledge.

Real-World Example - An attacker captures unencrypted Wi-Fi to steal login credentials.

(ii) Active Attack - An active attack involves altering, modifying or disrupting data transmission. These attacks are more harmful as they can lead to data loss, corruption or system compromise.

• Characteristics -

- Easier to detect because the attacker modifies data or systems.
- Focus on unauthorized modification, destruction or disruption.

examples:

- Denial of Service (DoS):- An attacker floods a server with traffic to make it unavailable to legitimate users.
- Man-in-the-Middle (MITM)- An attacker intercepts and alters communication between two parties without their knowledge.
- Spoofing - An attacker impersonates a legitimate user or system to gain unauthorized access.
- SQL Injection - injecting malicious SQL queries into a database to manipulate.
- Phishing - Sending fraudulent emails to trick users into revealing sensitive information.

Real-World Example - A hacker alters a bank transaction to redirect funds to their account in an MITM attack.

• Key differences:-

Aspect	Passive Attack	Active Attack
Detection	Hard to Detect	Easier to Detect
Goal	Gather information	Alter, disrupt or destroy data/system
Impact	Loss of confidentiality	Loss of integrity, availability or both.
Example	Eavesdropping, traffic analysis	DoS, MITM, replay attack

• Section - C

(a) Explain security systems development life cycle in detail?

Ans The Security System Development Life Cycle (SSDLC) is a structured approach to integrating security into every phase of system development to ensure confidentiality, integrity and availability. It consists of six key phases:

(i) Investigation -

- Identify security requirements and risks.
- Define objectives, scope and feasibility.

Ex- Conducting a risk management assessment to determine potential threats.

(ii) Analysis :-

- Examine current security policies and vulnerabilities.
- Identify regulatory compliance requirements.

ex:- Reviewing existing firewalls and encryption protocols.

(iii) Design :-

- Develop security architecture and controls.
- Define security policies, access control mechanisms, and encryption strategies.

ex: Designing multi-factor authentication (MFA) for user access.

(iv) Implementation :-

- Deploy security mechanisms such as firewalls, IDS/IPS and encryption.

- Configure and test security measures.

ex: Installing an intrusion detection system (IDS) to monitor threats.

(v) Testing & Evaluation :-

- Conducts penetration testing and vulnerability assessments.

- Ensure compliance with security standards (ISO 27001, NIST, etc.).
- Simulating a cyberattack to test system defenses.

(vi) Maintenance & Continuous Monitoring:-

- Regularly update security policies and patches vulnerabilities.
- Monitor logs for suspicious activities.
- Implementing automated threat detection tools for real-time monitoring.

In conclusion, The SecSDLC ensures security is embedded from the start, reducing risks and strengthening system resilience against cyber threats.

(b) What do you understand by balancing information security and access?

Ans Balancing information security and access means ensuring that data and systems are protected from threats while remaining accessible to authorized users. A strict security can make access difficult, while too much accessibility can lead to vulnerabilities.

Key Aspects of Balance:-

- Security vs. Usability** - Strong security (e.g., complex passwords, multi-factor authentication) can slow down workflows, while ease of access (e.g., simple passwords, open networks) increases risks.
- Least Privilege Principle** :- Users should have only the necessary access rights to minimize risks.
- Role-Based Access Control (RBAC)** :- Access permission should be assigned based on job roles to prevent unauthorized use.

- (iv) Authentication and Authorization :- Implementing secure yet efficient login methods, such as biometric authentication, ensures both security and ease of access.
- (v) Encryption and Secure Access :- Data should be encrypted but accessible through secure channels like VPNs.

ex:- A Bank must protect customer data with encryption and authentication while ensuring that customers and employees can quickly access necessary services.

2. (a) What are the various approaches to information security implementation?

Ans Organizations use different approaches to implement information security based on their needs, risks, and regulatory requirements. The main approaches include:

(i) Layered Security (Defense in Depth) :-

- Involves multiple layers of security controls to protect against different types of threats.
- ex:- A company uses firewalls, antivirus software, intrusion detection system (IDS) and encryption to protect its network.

(ii) Risk-Based Approach :-

- Identifies and prioritizes security measures based on risk assessment.

ex:- A financial institution invests heavily in fraud detection and encryption, as financial data is highly sensitive.

(iii) Compliance-Based Approach :-

- Focuses on adhering to industry standards and regulations.

ex:- A healthcare organization implements strict security controls

to comply with HIPAA regulations for patient data protection.

(iv) Zero Trust Model:-

- Assumes that threats can exist both inside and outside the network and enforces strict identity verification.
- ex: Employees must verify their identity at multiple checkpoints before accessing company systems.

(v) Perimeter Security Approach:-

- Secure the organization's external boundaries using firewalls, VPNs, and access controls.
- ex: A corporate network uses a firewall to block unauthorized external access.

(vi) Identity and Access Management-

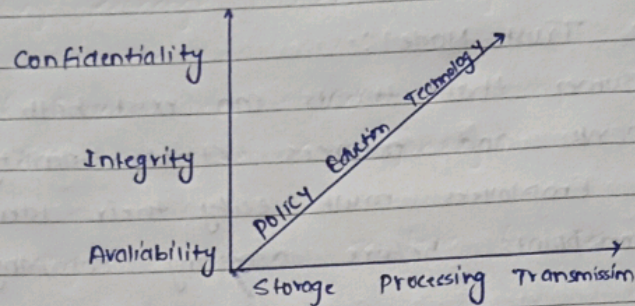
- Ensures only authorized users have access to systems through authentication and role-based access controls.
- ex: A company implements multi-factor authentication (MFA) for all employees.

Each approach has its strengths, and organizations often combine multiple approaches to create a comprehensive security strategy.

(2) (b) Explain CNSS security model?

Ans The CNSS Security Model, also known as the McCumber cube, was developed by the Committee on National Security Systems (CNSS). It provides a comprehensive framework for information security by integrating security objectives, information states, and security measures.

• Structure of the CNSS Model :-



The model is represented as a 3D cube with three dimensions :-

(i) Security Objectives (What to Protect)

- Confidentiality - Ensures that only authorized users can access information.
- Integrity - Ensuring data accuracy and protection from unauthorized modifications.
- Availability - Ensuring information is accessible when needed.

(ii) Information States (When to Protect)

- Storage (At Rest) :- Protecting data stored on devices or servers.
- Transmission (In transit) :- Securing data as it moves through networks.
- Processing (In Use) :- Ensuring data is protected while being processed.

(iii) Security Measures (How to Protect ?)

- Policy - Implements security policies and procedures.
- Technology - Using firewalls, encryption, authentication, and other security tools.
- Education & Awareness - Training employees on security best practices.

Shruti
28/5/23